Informe de prueba de penetracion

Cliente: **Distribuidora Andina S.A.** (ficticia) | Alcance: portal-clientes.andina.example (203.0.113.40) y red de desarrollo 10.10.30.0/24 | Periodo: 8-12 sep 2026

DATOS FICTICIOS - material educativo.

Observaciones (redaccion narrativa)

En el portal de clientes (portal-clientes.andina.example) se encontro el directorio de control de versiones publicado en el servidor web, lo que expone codigo fuente y archivos de configuracion con credenciales. Consideramos este hallazgo de severidad alta (CWE-527).

El formulario de inicio de sesion del mismo portal presenta una inyeccion SQL (CWE-89) que permite eludir la autenticacion. Severidad critica: no requiere credenciales y el portal esta expuesto a Internet.

La API de facturas permite a un cliente autenticado consultar facturas de otros clientes modificando el identificador (IDOR, CWE-639). Severidad alta por exposicion de datos personales y fiscales.

En la red de desarrollo, el servidor wiki-interna (10.10.30.40) ejecuta Atlassian Confluence 8.3.2, afectado por CVE-2023-22515. Recomendamos actualizar de inmediato.

El servidor de integracion continua jenkins-ci (10.10.30.50) ejecuta Jenkins 2.426.2, afectado por CVE-2024-23897. Ademas, la politica de contrasenas del portal no exige longitud minima ni bloqueo por intentos fallidos (severidad media).

Recomendaciones generales

Retirar el directorio de versionado del servidor y rotar credenciales; usar consultas parametrizadas; validar autorizacion por objeto en la API; actualizar Confluence y Jenkins; endurecer la politica de contrasenas.